

Port-Scan auf einen Host durchführen

Ein Port-Scan gibt darüber Aufschluss, welche Dienste ein Host im Netzwerk anbietet. Denn hinter einem Port (TCP bzw. UDP) lauscht ein Dienst, sofern er gestartet ist. Im Prinzip geht es darum herauszufinden, ob es einen offenen Port gibt, der nicht offen sein darf.

Für diese Aufgabe wählen wir das Standard-Gateway im lokalen Netzwerk, das wir auf seine Verbindungsmöglichkeiten prüfen.

Aufgabe

- a. Finden Sie die IP-Adresse des Standard-Gateways heraus.
- b. Finden Sie heraus, welche Ports offen sind.
- c. Stellen Sie fest, welche Möglichkeiten des Zugriffs es gibt.

Lösung mit nmap

Die IP-Adresse des Standard-Gateways findet man in Windows in der Eingabeaufforderung (Startmenü: Ausführen "cmd") mit "ipconfig /all" heraus. Bei Linux hilft der Befehl "route -n" weiter (Zeile mit Ziel 0.0.0.0).

Typischerweise verwendet man für diese Aufgabe einen Port-Scanner, den man auf die IP-Adresse des Hosts loslässt. In diesem Fall die IP-Adresse des Standard-Gateways. Port-Scanner gibt es für jedes Betriebssystem.

In diesem Fall nehmen wir den Network-Mapper "nmap".

➔ `nmap {IP-Adresse_des_Hosts}`

Das Ergebnis liefert eine Liste mit Ports (bis Port 1000), die offen sind und welches Anwendungsprotokoll typischerweise über diesen Port kommuniziert.

Es kann auch sein, dass "nmap" keine Liste liefert und zum Beispiel in der Ergebnis-Ausgabe "All 1000 scanned ports on {IP-Adresse_des_Hosts} are filtered" vermerkt. Das wäre ziemlich gut, weil der Host Port-Scans abzublocken versucht.

Wenn man alle Ports scannen will:

➔ `nmap -p- {IP-Adresse_des_Hosts}`

Hinweis: Man sollte nicht unbedacht einen Port-Scan auf irgendeine IP-Adresse losstreuen. Port-Scans werden von Administratoren als Angriffsversuche gewertet, die herausfinden sollen, ob es angreifbare Dienste und Server gibt.

Netzwerk-Scanning (Host Discovery)

Unter dem sehr allgemeinen Begriff "Scanning" versteht man in der Regel das Auskundschaften eines möglichen Angriffsziels (Host Discovery). Entweder ist es schon bekannt oder man will es noch entdecken und dann auf Schwachstellen analysieren.

Was ist Scanning?

Beim Scanning will man als Systemadministrator, Pentester oder Hacker herauszufinden, auf welche Weise eine TCP/IP-Verbindung zu einem oder mehreren Hosts aufgebaut werden kann.

Man unterscheidet beim Scanning, ob man einen ganzen IP-Adressbereich, also alle Hosts in einem Subnetz scannt oder ob man nur einen einzigen Host scannt. Beim Scanning eines Adressbereichs geht es in der Regel darum, die verfügbaren Hosts im Adressbereich zu ermitteln, deren Aufgabe zu bestimmen und Hosts mit Schwachstellen zu erkennen.

Beim Scanning eines einzelnen Hosts, geht es darum, die auf einem Host laufenden Dienste, sowie die verwendeten Firewall- bzw. Filterregeln zu bestimmen. Man kann dabei auch eventuelle Schwachstellen erkennen, um diese als Administrator zu beheben oder als Angreifer auszunutzen, um in diese Systeme einzudringen.

Teilbereiche des Scannings (Auswahl)

- Ping-Scanning
- Port-Scanning
- Service-Identification
- OS-Identification
- Vulnerability-Scanning
- IPv6-Scanning

Aufgaben und Ziele beim Scanning

- Erkennung von aktiven Systemen
- Erkennung offener Ports (TCP/UDP)
- Erkennung verwendeter Dienste und deren Version
- Erkennung verwendeter Betriebssysteme und deren Version
- Erkennung von Schwachstellen

Alle diese Ziele dienen dem Zweck, Angriffsflächen in Diensten, Betriebssystemen und installierter Software sichtbar zu machen.

Ping-Scan / Ping-Scanning

Ein Ping-Scan ermittelt die Erreichbarkeit eines oder mehrerer Ziele im Netzwerk. Es geht darum zu erkennen, ob ein Host erreichbar ist oder nicht. Wenn man den Ping-Scan auf ein ganzes Netzwerk (Subnetz) anwendet, dann kann man ermittelt, welche Rechner online sind.

- [Ping-Scanning \(Grundlagen\)](#)
- [Ping-Scanning mit NMAP](#)
- [Host-Discovery: Welche Geräte sind im lokalen Netzwerk aktiv?](#)

Port-Scan / Port-Scanning

Auch wenn das Erkennen von Sicherheitslücken und Schwachstellen der häufigste Grund für das Port-Scanning ist, kann man damit auch eine Inventur von Computern und der angebotenen Dienste erstellen. Weitere Anwendungen sind das Prüfen der Einhaltung von Richtlinien, Verfügbarkeitstests und Fehlersuche im Netzwerk.

Im Vergleich zum Ping-Scanning geht es beim Port-Scanning nicht nur darum, ob und welche Hosts aktiv sind, sondern auch welche Anwendungen aktiv und erreichbar sind. Die Erreichbarkeit wird dabei über den Zustand der Ports bestimmt. Typischerweise sind die Ports offen, geschlossen oder gefiltert. Besonders offene Ports sind interessant. Hier lohnt die weitere Untersuchung, weil hier Anwendungen zur Kommunikation bereit sind.

- [Port-Scanning \(Grundlagen\)](#)
- [Port-Scanning mit NMAP](#)

IPv6-Scanning

Die typischen Scan-Methoden, die bei IPv4 gelten, funktionieren in der Regel bei IPv6 nicht mehr. Deshalb muss man IPv6-Scanning getrennt von anderen Scanning-Methoden betrachten. Hier gelten anderen Regeln und Funktionsweisen.

OS & Service Identification

Werden beim Port-Scanning einige Ports als offen erkannt, gilt es herauszufinden, welche Anwendungen genau auf dem entfernten System läuft. Interessant ist auch, welches Betriebssystem zum Einsatz kommt, weil die Kombination aus Betriebssystem und Anwendung oftmals Sicherheitslücken offenbart, über die man natürlich im Vorfeld informiert sein muss. Alternativ bestünde die Möglichkeit, eventuelle Sicherheitslücken zu recherchieren.

- [OS & Service Identification \(Grundlagen\)](#)
- [OS & Service Identification mit NMAP](#)

Vulnerability-Scanning

Das Vulnerability-Scanning gehört nicht mehr zum klassischen Scanning. Hier werden Angriffsziele systematisch und automatisiert nach Schwachstellen geprüft. Der nächste Schritt wäre schon das Exploiting.

Ping - Paket Internet Groper / pathping

Ping steht für Paket Internet Groper und ist das meistgenutzte Tool um eine Netzwerkverbindung zu einer anderen Station zu testen oder einfach nur um den lokalen TCP/IP-Stack zu prüfen.

Ping steht auf der Kommandozeile/Konsole als Befehl "ping" zur Verfügung. Die entfernte Station kann über die IP-Adresse oder den Domain- bzw. WINS-Namen angesprochen werden. Bei Bedarf übernimmt ping die Namensauflösung.

Ping kennt mehrere Optionen, die mehr Informationen liefern. Hierauf wird hier nicht weiter eingegangen. Das Hilfesystem des verwendeten Betriebssystems gibt weitere Auskunft.

Unter Windows führt der ping-Befehl den Ping nur insgesamt 4 mal hintereinander aus. Bei Unix oder Linux führt der ping-Befehl den Ping so oft aus, bis der Befehl abgebrochen wird. Zum Abbruch muss CTRL und C (CTRL + C) gedrückt werden.

Beispiel für die Anwendung von Ping

Microsoft Windows XP [Version 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.

C:\>ping www.elektronik-kompodium.de

Ping www.elektronik-kompodium.de [212.227.253.68]
mit 32 Bytes Daten:

Antwort von 212.227.253.68: Bytes=32 Zeit=73ms TTL=56
Antwort von 212.227.253.68: Bytes=32 Zeit=73ms TTL=56
Antwort von 212.227.253.68: Bytes=32 Zeit=72ms TTL=56
Antwort von 212.227.253.68: Bytes=32 Zeit=72ms TTL=56

Ping-Statistik für 212.227.253.68:

Pakete: Gesendet = 4, Empfangen = 4, Verloren = 0 (0% Verlust),
Ca. Zeitangaben in Millisek.:
Minimum = 72ms, Maximum = 73ms, Mittelwert = 72ms

Was passiert bei einem Ping?

Bei der Ausführung des Befehls ping wird ein ICMP-Paket vom Typ ICMP Echo Request an die Netzwerk-Station gesendet. Wenn die Station das ICMP-Paket empfangen hat, sendet sie ein ICMP-Paket vom Typ ICMP Echo Reply zurück. Ein Windows-Betriebssystem führt insgesamt 4 ICMP-Meldungen aus. Bei Unix/Linux muss ping durch STRG+C abgebrochen werden.

Anwendung von Ping

1. Mit Ping kann man die Laufzeit eines Paketes vom Sender zum Empfänger ermitteln. Dazu wird die Zeit, bis das Echo Reply eintrifft, halbiert.
2. Mit Ping kann geprüft werden, ob eine Station Kontakt zum Netzwerk hat: Mit ping auf eine Nachbarstation oder das Standard-Gateway.
3. Mit Ping auf den localhost oder 127.0.0.1 kann geprüft werden, ob der TCP/IP-Stack auf der lokalen Station überhaupt installiert ist.
4. Wichtige Stationen (z. B. Server) können mit regelmäßigen Pings auf Verfügbarkeit überprüft werden. Allerdings bezieht sich das auf die Verfügbarkeit des TCP/IP-Stacks oder aber die Server-Erreichbarkeit.

Erfolgreicher Ping auf den localhost (127.0.0.1):

Microsoft Windows XP [Version 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.

C:\>ping localhost

Ping SCHNABEL [127.0.0.1] mit 32 Bytes Daten:

Antwort von 127.0.0.1: Bytes=32 Zeit<1ms TTL=128
Antwort von 127.0.0.1: Bytes=32 Zeit<1ms TTL=128
Antwort von 127.0.0.1: Bytes=32 Zeit<1ms TTL=128
Antwort von 127.0.0.1: Bytes=32 Zeit<1ms TTL=128

Ping-Statistik für 127.0.0.1:

Pakete: Gesendet = 4, Empfangen = 4, Verloren = 0 (0% Verlust),
Ca. Zeitangaben in Millisek.:
Minimum = 0ms, Maximum = 0ms, Mittelwert = 0m

Erfolgsloser Ping auf eine nicht vorhandene IP-Adresse im selben Subnetz:

Microsoft Windows XP [Version 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.

C:\>ping 192.0.0.1

Ping wird ausgeführt für 192.0.0.1 mit 32 Bytes Daten:

Zeitüberschreitung der Anforderung.
Zeitüberschreitung der Anforderung.
Zeitüberschreitung der Anforderung.
Zeitüberschreitung der Anforderung.

Ping-Statistik für 192.0.0.1:

Pakete: Gesendet = 4, Empfangen = 0, Verloren = 4 (100% Verlust),

pathping

pathping ist eine Erweiterung von ping. Es analysiert die Stationen ähnlich wie tracert oder traceroute über die gesamte Strecke, die ein Datenpaket zum Ziel nehmen muss. In Abhängigkeit der überwundenen Stationen liefert pathping nach ein paar Minuten eine Statistik über die Erreichbarkeit der einzelnen Stationen.

Microsoft Windows XP [Version 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.

C:\>pathping www.elektronik-kompendium.de

Routenverfolgung zu www.elektronik-kompendium.de [212.227.253.68]
über maximal 30 Abschnitte:
0 SCHNABEL.t-online.de [192.168.168.12]
1 192.168.168.8
2 217.5.98.159
3 217.237.156.234
4 f-ea1.F.DE.net.DTAG.DE [62.154.17.182]
5 so-1000.gw-backbone-a.ffmpeg.schlund.net [212.227.112.18]
6 so-4000.gw-backbone-a.bs.ka.schlund.net [212.227.112.124]
7 a0kac1a.gw-distp-a.bs.ka.schlund.net [212.227.116.210]
8 pkad1.gw-prtr-r2-a.bs.ka.schlund.net [212.227.34.194]
9 elektronik-fibel.de [212.227.253.68]

Berechnung der Statistiken dauert ca. 225 Sekunden...

Quelle zum Abs. Knoten/Verbindung

Abs. Zeit Verl./Ges.= % Verl./Ges.= % Adresse

0 SCHNABEL.t-online.de [192.168.168.12]
0/ 100 = 0% |
1 0ms 0/ 100 = 0% 0/ 100 = 0% 192.168.168.8
0/ 100 = 0% |
2 --- 100/ 100 =100% 100/ 100 =100% 217.5.98.159
0/ 100 = 0% |
3 64ms 0/ 100 = 0% 0/ 100 = 0% 217.237.156.234
0/ 100 = 0% |
4 67ms 0/ 100 = 0% 0/ 100 = 0% f-ea1.F.DE.net.DTAG.DE
0/ 100 = 0% |
5 77ms 0/ 100 = 0% 0/ 100 = 0% so-1000.gw-backbone-a.ffmpeg....
0/ 100 = 0% |
6 75ms 0/ 100 = 0% 0/ 100 = 0% so-4000.gw-backbone-a.bs.ka....
0/ 100 = 0% |
7 --- 100/ 100 =100% 100/ 100 =100% a0kac1a.gw-distp-a.bs.ka....
0/ 100 = 0% |
8 77ms 0/ 100 = 0% 0/ 100 = 0% pkad1.gw-prtr-r2-a.bs.ka....
0/ 100 = 0% |
9 75ms 0/ 100 = 0% 0/ 100 = 0% elektronik-fibel.de

Ablaufverfolgung beendet.

Host-Discovery: Welche Geräte sind im lokalen Netzwerk aktiv? (Network Scan)

Host-Discovery bezeichnet Maßnahmen und Methoden, um alle erreichbaren Systeme in einem Netzwerk zu identifizieren. In der Regel versucht man Systeme zu identifizieren, die über eine IP-Adresse erreichbar sind.

Während man im ersten Schritt versucht alle Hosts eines Netzwerks zu identifizieren (Network Scan), erfolgt im Anschluss die detaillierte Untersuchung eines Host, um dessen Hardware, Betriebssystem, laufende Dienste und offene Ports herauszufinden (Host Scan).

Ein guter Netzwerk-Administrator weiß, welche Hosts sich im eigenen Netzwerk befinden. In einem kleinen lokalen Netzwerk wird man sich allerdings keine Mühe machen, eine Liste händisch zu pflegen. Insbesondere deshalb, weil Clients ihre IPv4-Adresse in der Regel per DHCP bekommen. Doch gerade deshalb ist es wichtig, Mittel und Wege zu kennen, um alle genutzte IP-Adressen zu ermitteln. Es geht dabei auch um die Fragestellung "Welche Geräte sind im lokalen Netzwerk aktiv?".

Auf der anderen Seite möchte man als Administrator vielleicht feststellen, welche IP-Adressen generell vergeben sind, um zum Beispiel eine freie IP-Adresse fest vergeben zu können.

Übersicht: Methoden und Tools für Host-Discovery

Um sich einen Überblick über alle im lokalen Netzwerk befindlichen IP-Hosts zu machen, gibt es verschiedene Tools. Das heißt, für das Host-Discovery gibt es mehrere Wege. Probieren Sie die verschiedenen Tools aus und vergleichen Sie die Ergebnisse.

- Host-Discovery mit ARP (Network Scan)
- Host-Discovery mit IP (Network Scan)
- Host-Discovery mit ARP-SCAN (Network Scan)
- Host-Discovery mit Netdiscover (Network Scan)
- Host-Discovery mit NMAP (Host und Network Scan)
- Host-Discovery mit FPING (Host und Network Scan)
- Host-Discovery mit Ping mit Windows und Linux

Host-Discovery beschränkt sich nicht auf diese Tools. Denkbar wäre die Nutzung weiterer Tools.

Root-Rechte

Es empfiehlt sich mit Root-Rechten zu arbeiten.

➔ `sudo -i`

Sie können zur vorherigen Sitzung mit "exit" zurückkehren.

Host-Discovery mit ARP (Network Scan)

"arp" ist ein Kommandozeilen-Tool, dass standardmäßig vorhanden sein sollte. Es sollte sowohl unter Windows, Linux als auch macOS funktionieren.

- ➔ Arp
- ➔ arp -n
- ➔ arp -a

"arp" ist ein vielseitiges Tool, mit dem man den ARP-Cache abfragen kann. Mit dem Einsatz der richtigen Optionen, bekommt man die richtigen Informationen aller erreichbaren Hosts, die auf Schicht 2 des OSI-Schichtenmodells miteinander verbunden sind.

Lösung: Host-Discovery mit IP (Network Scan)

Das Tool "ip" ist praktisch bei jedem Linux standardmäßig dabei. Das heißt, man braucht es nicht nachträglich zu installieren. Es gehört zur Grundausstattung.

Um an die IP-Adressen aller Hosts im gleichen Netzwerk zu kommen gibt es verschiedene Möglichkeiten. Die folgenden Befehle listen alle IPv4- und IPv6-Adressen und die dazugehörige MAC-Adressen auf:

- ➔ ip -4 neighbor show
- ➔ ip -4 n

- ➔ ip -6 neighbor show
- ➔ ip -6 n

Ob die Ausgabe von "ip" sinnvoll und aussagekräftig ist hängt von der Netzwerk-Umgebung ab. Es gibt Situationen, bei denen "ip" nur sehr wenige Hosts liefert, obwohl es eindeutig mehr sein müssten. In der Regel wird "ip" nicht alle IP-Adressen auflistet.

"ip" hat allerdings den Vorteil, dass es auch dann IP-Adressen liefert, wenn andere Tools versagen. Zum Beispiel, weil der Netzwerk-Administrator den aktiven Datenverkehr entsprechender Tools verhindert.

"ip" agiert rein passiv und ermittelt die Informationen, die im ARP-Cache enthalten sind. Der Inhalt des ARP-Caches bildet sich aus dem allgemeinen Netzwerk-Verkehr, der auf dem betreffenden Host eingeht.

- [ARP - Address Resolution Protocol](#)

Lösung: Host-Discovery mit ARP-SCAN (Network Scan)

ARP-Scan ist eine Möglichkeit um Host auf Schicht 2 (OSI-Schichtenmodell) in einem Ethernet-Netzwerk oder WLAN (nach IEEE 802.11) zu finden.

Installieren, falls es noch nicht installiert ist.

➔ apt-get install arp-scan

Anschließend lässt man einen Netzwerk-Scan durchlaufen. Der dauert in der Regel nur ein paar Sekunden. Bei größeren Netzwerken (Klasse A und B) sollte man das besser lassen. Es sei denn, man ist dazu befugt.

➔ arp-scan -localnet

➔ arp-scan -l

Mit ARP-Scan werden im aktuellen Subnetz an alle IP-Adressen einen ARP-Request. Das Ergebnis ist eine Liste aller antwortenden Hosts.

Betrachten Sie die Ausgabe als Momentaufnahmen, die sich nach mehrmaliger Wiederholung ändern kann. ARP-SCAN erzeugt eine nahezu vollständige Liste, die sich leicht in eine Excel-Tabelle einfügen lässt.

Für eine übersichtliche Darstellung aller Hosts in einem bestimmten Subnetz mit MAC-Adresse und Interface-Hersteller eignet sich folgendes Kommando:

➔ arp-scan -vN -I eth0 192.168.1.0/24

Darstellung aller Hosts, deren Hardware eine bestimmte Hersteller-Kennung hat (hier Raspberry Pi):

➔ arp-scan -vN -I eth0 192.168.1.0/24 | grep "b8:27:eb"

- [ARP - Address Resolution Protocol](#)

Host-Discovery mit Netdiscover (Network Scan)

Netdiscover ist ein Tool für das Host Discovery unbekannter Netze. Es hat einen aktiven und einen passiven Modus. Der passive Modus ist deshalb interessant, weil das Tool dann keinen Datenverkehr erzeugt, sondern einfach nur lauscht.

Netdiscover stammt noch aus einer Zeit, als Wardriving cool war und man von offenen und ungeschützten WLANs möglichst schnell eine Liste erreichbarer Geräte haben wollte. Heute ist Wardriving kein Thema mehr, weil es keine offenen WLANs mehr gibt. Und deshalb ist Netdiscover auch in Vergessenheit geraten.

Trotzdem ist Netdiscover gerade wegen seinem passiven Modus für verstecktes Host Discovery interessant. Denn man kann Netdiscover nicht nur in WLANs, sondern auch in geschwächten Netzwerken einsetzen.

Netdiscover installieren (falls nicht vorhanden):

➔ apt-get install netdiscover

Netdiscover im passiven Modus:

- ➔ netdiscover -i eth0 -p
- ➔ netdiscover -i wlan0 -p

Im passiven Modus sammelt Netdiscover ARP-Requests/-Replies ein. Bis man eine vollständige Liste aller Hosts bekommt, kann es natürlich einige Zeit dauern. Das hängt im wesentlichen vom Datenverkehr im lokalen Netzwerk ab. Allerdings ist das die unauffälligste Methode, um im verborgenen Host Discovery zu betreiben.

Die Ausführung von Netdiscover beendet man mit Strg + C.

Netdiscover im aktiven Modus:

- ➔ netdiscover -i eth0 -r 192.168.1.0/24
- ➔ netdiscover -i wlan0 -r 192.168.1.0/24 -c 3

Im aktiven Modus sendet Netdiscover selbst ARP-Pakete aus, um Geräte zu finden. Dabei sollte man die Suche auf ein bestimmtes Subnetz mit der Option "-r" eingrenzen. Weil in WLANs eher mal Paketverluste auftreten können, lässt man Netdiscover den Scan mit der Option "-c 3" dreimal durchführen.

Host-Discovery mit NMAP (Host und Network Scan)

NMAP ist ein Netzwerk-Scanner, der beispielsweise anzeigt, welche Teilnehmer sich noch im lokalen Netzwerk befinden.

Installieren, falls NMAP noch nicht installiert ist.

- ➔ apt-get install nmap

NMAP ist sehr flexibel und erwartet die Angabe einer IP-Adresse, eines IP-Adressblocks oder eines Hostnamens. Es kann also nicht nur die Teilnehmer des eigenen lokalen Netzwerks ermitteln, sondern auch darüber hinaus.

Der Adressbereich des lokalen Netzwerks ist nicht immer gleich. Hier nehmen wir an, dass es 192.168.1.0 ist. Hier wollen wir den Adressblock von 192.168.1.1 bis 192.168.1.255 scannen:

- ➔ nmap -sP -oG - 192.168.1.0/24

Dieses NMAP-Kommando ist ein TCP-Ping-Scan ("-sP"). Es ist eigentlich kein Ping-Scan, sondern eher eine sinnvolle Erweiterung zu einem klassischen Ping. Der TCP-Ping-Scan kombiniert den klassischen Ping (ICMP-Echo) mit dem TCP-SYN- und TCP-ACK-Scan auf die Ports 443 und 80. Befindet sich der Host im eigenen Subnetz, dann arbeitet der TCP-Ping-Scan nicht mit ICMP-Nachrichten, sondern mit ARP-Requests.

Die Kommando-Option "-oG -" sorgt für eine übersichtliche Darstellung.

Dieses NMAP-Kommando versucht alle IP-Adressen im Adressblock zu kontaktieren und erzeugt dann eine Liste aller erreichbaren IP-Adressen mit den Hostnamen der

Computer. Diese Liste ist allerdings unvollständig und kann deshalb nur als Momentaufnahme angesehen werden.

➔ `nmap -sP -sn -oG - 192.168.1.0/24`

Die Option "-sn" führt den Scan ohne Port-Scan aus.

Weniger bekannt ist die NMAP-Option "-sL". Zumindest wird sie in einschlägigen Anleitungen, Tutorials und der Literatur selten erwähnt. Eigentlich unverständlich, denn der List-Scan von NMAP ist eine ziemlich coole Sau.

➔ `nmap -sL 192.168.1.0/24`

Der List-Scan zählt einfach alle IP-Adressen im angegebenen Subnetz auf und führt für jede Adresse eine Reverse-DNS-Abfrage durch. Ein Grund für diesen Scan ist den IP-Adressbereich auf Korrektheit zu prüfen, bevor man sich an falschen Hosts zu schaffen macht.

Man kann den Ping-Schritt auch auslassen, indem man den Ping ausschaltet ("-sL -PN"). Das besonders Tolle dabei ist, dass es nichts unverdächtigeres gibt, als DNS-Datenverkehr. Außerdem werden die Hosts nicht direkt kontaktiert und können somit auch nicht bemerken, dass sie ausspioniert werden.

Die Hostnamen selber geben häufig Auskunft über die Funktion eines Hosts. Man kann auf diese Weise schneller lohnenswerte Ziele identifizieren.

Eine Variante davon ist das folgende Kommando, bei dem eine Namensauflösung im lokalen Netzwerk durchgeführt wird.

➔ `nmap -sP -PN -R --dns-servers {DNS-SERVER} 192.168.1.0/24 | grep -i .local`

Alle NMAP-Kommandos sind, wenn sie im lokalen Netzwerk angewendet werden, nicht besonders zuverlässig. Gemeint ist, dass das Ergebnis nicht alle Hosts auflistet. Bei der Ausführung der Kommandos sieht das Ergebnis immer wieder anders aus. Das Ergebnis ist also nur eine Momentaufnahme. Deshalb empfiehlt es sich in einem lokalen IP-Netzwerk parallel mit "arp", "ip" oder "arp-scan" zu arbeiten. Diese Kommandos sind beim Auffinden aller Hosts zuverlässiger.

- [NMAP - Network Mapper](#)

Host-Discovery mit FPING (Network Scan)

FPING sendet mehrere ICMP-Echo-Requests ins Netzwerk. Im Gegensatz zu anderen Ping-Kommandos arbeitet es mit parallelen Pings, weshalb PFING Ergebnis schneller liefert.

Installieren, falls es noch nicht installiert ist.

➔ `apt-get install fping`

Fping ermittelt IP-Adressen und Hostnamen:

➔ `fping -aAnqs -g 192.168.1.0/24 -r 1`

- [ICMP - Internet Control Message Protocol](#)

Network Scan mit CMD (Windows) und Bash (Linux)

Gelegentlich kommt es vor, dass man auf dem aktuellen System, an dem man arbeitet, die genannten Tools nicht zur Verfügung hat und auch nicht nachinstallieren kann.

Beispielsweise, weil man mit anderen Systemen arbeitet oder keine Berechtigung hat. Deshalb im folgenden je ein Kommando, dass unter Windows und Linux funktioniert.

Host-Discovery auf der Windows-Kommandozeile:

➔ `for /L %i in (1,1,254) do @ping -n 1 -w 1 192.168.1.%i | find "from"`

Host-Discovery auf der Linux-Kommandozeile:

➔ `for i in $(seq 1 254); do ping -c 1 -W 1 192.168.1.$i | grep "from"; done`

Diese Kommandos funktionieren mit Ping und geben nur die Hosts aus, die per Ping erreichbar sind und darauf antworten.

Host Discovery mit Zeroconf (Network Scan)

In lokalen Netzwerken ist mit Zeroconf und seinen Implementierungen Bonjour (macOS und Windows) und Avahi (Linux) ein Dienst aktiv, der andere Hosts über Dienste und Hostnamen informiert. Diese Informationen kann man abrufen. Ein Nachteil ist, dass man Avahi nicht nutzen sollte, wenn man im lokalen Netzwerk anonym bleiben will. Denn Avahi ist sehr gesprächig, was man unter Umständen vermeiden will.

Avahi-Daemon und -Tools installieren:

➔ `apt-get install avahi-daemon avahi-utils`

Netzwerk nach Diensten durchsuchen:

➔ `avahi-browse -a`

Dieses Kommando beendet sich nicht von alleine. Beenden Sie es mit "Strg + C".

Das Kommando zeigt an, auf welchen Schnittstellen, welche Geräte erreichbar sind und welche Dienste sie annouciert haben.

- [Mehr Informationen über Zeroconf / Bonjour / Avahi](#)

Fazit: ARP, IP, NMAP, ARP-SCAN, Netdiscover oder FPING

Alle Tools arbeiten unterschiedlich, weil sie für unterschiedliche Zwecke entwickelt wurden.

Das Kommando IP arbeitet passiv und entnimmt seine Informationen aus dem ARP-Cache des Hosts an dem man das Kommando ausführt. Das kann die erste Aktion sein, um ein Netzwerk verdeckt auszukundschaften. Meistens liefert IP nicht viele Adressen. Manchmal ist IP aber auch das einzige Tool das funktioniert, wenn im Netzwerk Mechanismen arbeiten, die aktives Host-Discovery verhindern.

NMAP ermittelt IP-Adressen und dazugehörige Hostnamen. Dazu muss NMAP aktiv verschiedene Anfragen ins Netzwerk schicken und die Antworten auswerten. Das nimmt einige Zeit in Anspruch. Da die Arbeitsweise von NMAP bekannt ist, lässt sich die Arbeit mit NMAP durch Filter und IDS unterbinden.

ARP-SCAN und Netdiscover arbeiten auf der MAC-Schicht und ermitteln MAC-Adressen und die dazugehörigen IPv4-Adressen. Dabei stellt ARP-SCAN und Netdiscover (aktiver Modus) einfach ARP-Anfragen ins Netzwerk und wertet die Antworten aus. Diese Arbeitsweise ist weniger auffällig als NMAP, weil ARP-Anfragen in einem Netzwerk normal sind. Der aktive Modus von Netdiscover ist dabei nicht besser als ARP-SCAN. Netdiscover ist nur wegen seinem passiven Modus interessant, um unentdeckt zu bleiben. Allerdings kann es mehrere Stunden dauern, bis eine vollständige Liste zusammen kommt. Absolut unschlagbar ist Netdiscover in WLANs.

FPING ist nichts weiter als ein Ping, der auf ICMP-Echo-Requests basiert. Dabei erzeugt auch FPING Netzwerk-Verkehr, der gefiltert werden kann.

Beim Host-Discovery ist das Tool das richtige, dass die gewünschten Informationen liefert. Die Frage ist, brauche ich neben der IP-Adresse auch den Hostnamen oder die MAC-Adresse des Hosts. Dabei muss man berücksichtigen, dass die Informationen der verschiedenen Tools ganz unterschiedliche Qualitäten haben können. Zum Beispiel bei der Zuordnung von MAC-Adresse zum Gerätehersteller und auch bei der Ermittlung des Hostnamens.

Wichtig ist auch, egal welches Tool oder Kommando, es ist immer eine Momentaufnahme eines Netzwerks, das sich jederzeit ändern kann. In der Regel muss man sich mehrerer Tools und jedes Tool mehrmals bedienen, um umfassende und qualifizierte Information zu bekommen.

Quellen: <https://www.elektronik-kompodium.de/>